



Using AI For CVE Vulnrichment:

The VEX Generation Use Case

Piotr Karwasz and Munawar Hafiz

Talk Outline

- VEX Generation Toolset Project
- How Are The VEX Documents Generated?
- The Need For A Root Cause For A CVE
- The Challenges To Calculate The Root Cause
- How Does It Work In Practice?
- Open Questions

Motivation: Log4j @ Kafka

- Kafka 4.x migrated from Log4j 1.x to Log4j 2.x (post 2015 EOL)
- Log4j 2.x is highly modular (20+ optional components)
- Advanced features introduce additional **transitive** dependencies

Key takeaway:

Dependency choices in Log4j now affect security posture downstream

Producing VEXes for OSS Projects

Challenges

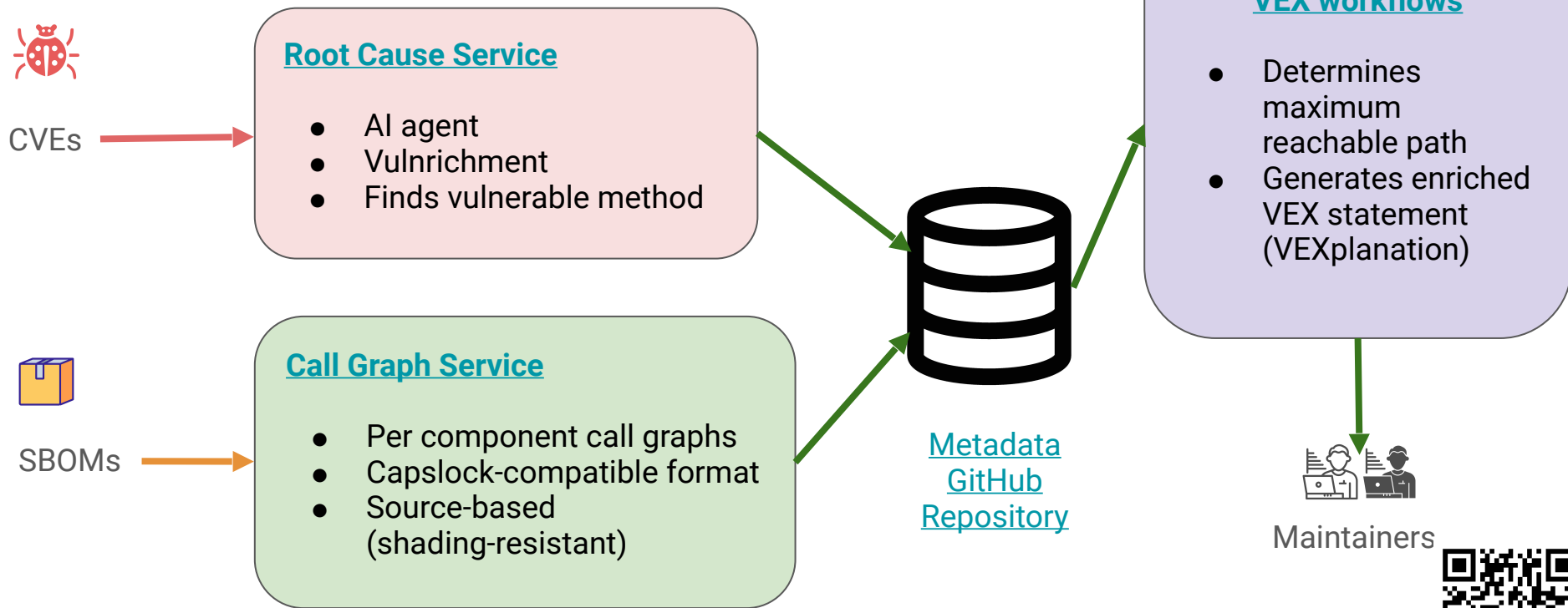
- Not required by the CRA (or other regulations)
- May consume significant volunteer time instead of funded downstream resources

Benefits

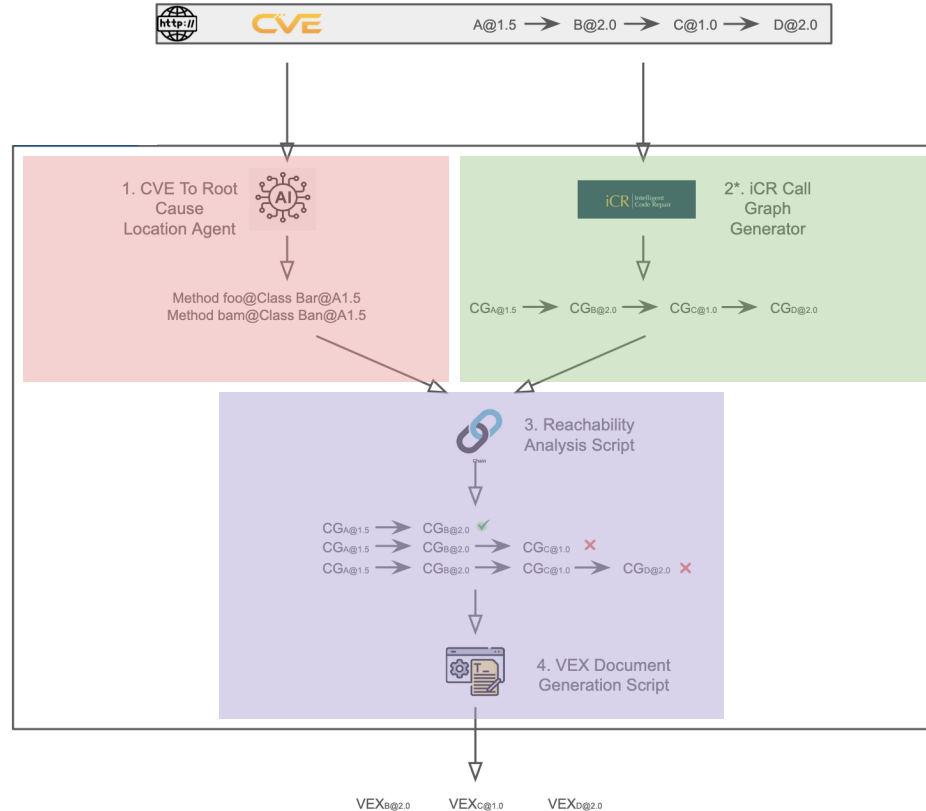
- Increases trust and confidence in the OSS project and its supply chain
- Saves time for downstream users, many of whom are also OSS projects
- **Can be automated**

Automation is the only scalable path for OSS VEX generation

High-Level Architecture



How Do The Components Work?



Root Cause: CVE-2026-24061



telnetd RCE as root vulnerability

`_var_short_name` function in `utility.c`

[inetutils](#) / [telnetd](#) / [utility.c](#)

Code

Blame

1925 lines (1677 loc) · 40.4 KB

```
1731         return terminaltype ? xstrdup (terminaltype) : NULL;
1732
1733     case 'u':
1734         return user_name ? xstrdup (user_name) : NULL;
1735
1736     case 'U':
1737         return getenv ("USER") ? xstrdup (getenv ("USER")) : xstrdup ("");
1738
```

Current Supply Chain Risk Assessment Solutions

- **Know your SBoM**
- Just matching components
- Matching component signatures (OmniBOR)
- Too many false warnings

Required Input

GHSA-vv9c-xxg7-wmv7

[Suggest an improvement](#)

Source <https://github.com/advisories/GHSA-vv9c-xxg7-wmv7>
Import Source <https://github.com/github/advisory-database/blob/main/advisories/github-reviewed/2025/09/GHSA-vv9c-xxg7-wmv7/GHSA-vv9c-xxg7-wmv7.json>
JSON Data <https://api.osv.dev/v1/vulns/GHSA-vv9c-xxg7-wmv7>
Aliases CVE-2025-6237

Summary InvokeAI has External Control of File Name or Path

Details **Path Traversal Vulnerability in InvokeAI**

A path traversal vulnerability in InvokeAI (versions < 6.7.0) allows an unauthenticated remote attacker to read files outside the intended media directory via the bulk downloads API.

The endpoint accepts a user-controlled file/item name and concatenates it into a filesystem path without proper canonicalization or allow-listing. By supplying sequences such as `../` (or absolute paths), an attacker can cause the server to traverse directories and return arbitrary files.

In certain storage or back-end configurations, abusing attacker-controlled paths can also lead to unintended overwriting or deletion of files referenced by the crafted path.

The issue is fixed in 6.7.0, which normalizes and validates input paths and rejects traversal attempts.

Affected versions: < 6.7.0 **Patched version:** 6.7.0

Database specific [\[\]](#)

```
{
  "nvd_published_at": "2025-09-18T09:15:35Z",
  "cwe_ids": [
    "CWE-22",
    "CWE-73"
  ],
  "github_reviewed": true,
  "github_reviewed_at": "2025-09-18T17:21:19Z",
  "severity": "CRITICAL"
}
```

References <https://nvd.nist.gov/vuln/detail/CVE-2025-6237>
<https://github.com/InvokeAI/InvokeAI/pull/8548/commits/aff565ae6ace1c8458f87245690bf0f0513f1b9e>
<https://github.com/InvokeAI/InvokeAI>
<https://github.com/InvokeAI/InvokeAI/blob/v6.0.0ai/InvokeAI/app/api/routers/images.py#L493-L524>
<https://github.com/InvokeAI/InvokeAI/releases/tag/v6.7.0>
<https://huntr.com/bounties/54ac9589-7c88-4f64-8512-8b2f19fbaedf>

Package

Name [invokeai](#)
[View open source insights on deps.dev](#)
Purl pkg:pypi/invokeai

Affected ranges

Type ECOSYSTEM
Events Introduced 0
Fixed 6.7.0

Affected versions

▼ 2.*

2.2.4.5	2.2.4.6	2.2.4.7	2.2.5	2.3.0a0	2.3.0a1	2.3.0a2	2.3.0a3
2.3.0rc3	2.3.0rc4	2.3.0rc5	2.3.0rc6	2.3.0rc7	2.3.0	2.3.1rc4	2.3.1
2.3.1.post 1	2.3.1.post 2	2.3.2	2.3.2.post 1	2.3.3rc1	2.3.3	2.3.4a0	2.3.4rc1
2.3.4	2.3.4.post 1	2.3.5rc1	2.3.5	2.3.5.post 1	2.3.5.post 2		

▶ 3.*

▶ 4.*

▶ 5.*

▶ 6.*

242 versions

Missing Data: Commit Hash In References



CVE-2025-58160

Log Injection in `tracing` framework (Rust)

References

<https://github.com/CVEProject/cvelistV5/tree/main/cves/2025/58xxx/CVE-2025-58160.json> 

<https://github.com/tokio-rs/tracing/security/advisories/GHSA-xwfm-jgwm-7wp5> 

<https://nvd.nist.gov/vuln/detail/CVE-2025-58160> 

Wrong Data: Commit Hash In References



CVE-2025-59047

Panic in `matrix-sdk-base` framework (Rust)

Commit `ce3b67f`

 **poljar** and **Hywan** committed on Sep 9, 2025 · ✖ 44 / 49

Update `bindings/matrix-sdk-ffi/CHANGELOG.md`

Co-authored-by: Ivan Enderlin <ivan@mt.io>

Signed-off-by: Damir Jelić <poljar@termina.org.uk>

 `main` (#5635) ·  `sdk-ffi/20250923` ... `matrix-sdk-0.16.0`

Filter files...

bindings/matrix-sdk-ffi

CHANGELOG.md

1 file changed +1 -1 lines changed

bindings/matrix-sdk-ffi/CHANGELOG.md

@@ -8,7 +8,7 @@ All notable changes to this project will be documented in this file.

8 8

9 9

10 10

Breaking changes:

11 -- The 'normalized_power_level' field has been removed from the `RoomMember`

11 + -- The 'normalized_power_level' field has been removed from the `RoomMember`

12 12 struct.

13 13 ([#5635](<https://github.com/matrix-org/matrix-rust-sdk/pull/5635>))

14 14

++

Comments 0

Missing Link: PURL To Git Repo Mapping (1 / 2)



CVE-2025-30065

RCE in `parquet-avro` module (Java)

Name <code>org.apache.parquet:parquet-avro</code> View open source insights on deps.dev 							
Purl <code>pkg:maven/org.apache.parquet/parquet-avro</code>							
Type ECOSYSTEM							
Events Introduced 0							
Fixed 1.15.1							
▼ 1.*							
1.7.0	1.8.0	1.8.1	1.8.2	1.8.3	1.9.0	1.10.0	1.10.1
1.11.0	1.11.1	1.11.2	1.12.0	1.12.1	1.12.2	1.12.3	1.13.0
1.13.1	1.14.0	1.14.1	1.14.2	1.14.3	1.14.4	1.15.0	

Missing Link: PURL To Git Repo Mapping (2 / 2)

`pkg:maven/org.apache.parquet/parquet-avro@1.15.0`

<https://github.com/apache/parquet-java>

<https://github.com/apache/parquet-java/tree/apache-parquet-1.15.0>

[https://github.com/apache/parquet-java/
tree/apache-parquet-1.15.0/parquet-avro](https://github.com/apache/parquet-java/tree/apache-parquet-1.15.0/parquet-avro)

Wrong Data: Version Grouping (1 / 2)



CVE-2025-58162

Arbitrary file write in MobSF (Python)

Affected versions [🔗](#)

▶ 3.*

▼ 4.*

4.1.3

4.3.0

4.3.2

4.4.0

Wrong Data: Version Grouping (2 / 2)

 MobSF / Mobile-Security-Framework-MobSF

[Code](#) [Issues 15](#) [Pull requests 10](#) [Actions](#) [Security 14](#) [Insights](#)

[Releases](#) [Tags](#)

 Tags

v4.4.2 
🕒 on Aug 30, 2025 🔗 de7bf03 📦 zip 📦 tar.gz 📄 Notes

v4.4.1 
🕒 on Aug 30, 2025 🔗 7f3bc08 📦 zip 📦 tar.gz 📄 Notes

v4.3.2 
🕒 on Mar 28, 2025 🔗 4b8bab5 📦 zip 📦 tar.gz 📄 Notes

v4.3.0 
🕒 on Jan 22, 2025 🔗 d1d3b7a 📦 zip 📦 tar.gz 📄 Notes

Empirical Study

140 CVEs

20 CVEs each for Java, Python, Go, Rust, JavaScript, C#, Ruby

102 root causes identified (73%)

97 accurate root causes (95%)

What's Next

- Not yet integrated into vulnerability databases
- Running cost: of \$0.20-0.50 per CVE
- Improved human-in-the-loop curation

Questions?

